

EntraID / 3LO: AC Gateway + AC Identity

Volume 3 — Multi-Agent Chains, Regulatory Compliance (DORA/NIS2),

Forward-Looking Protocol Landscape & Enterprise Maturity Model

GENAIAF-562 · GENAI Agent Foundry · June 2026

Builds on	Volume 1 (Standards, Architecture, Industry) + Volume 2 (Code, Vault, Runbook, OWASP)
This volume	Sections 19–25: Multi-Agent Auth Chains, A2A/MCP Protocol Stack, DORA/NIS2/EU AI Act Compliance, Maturity M
Audience	Architects, Security, Compliance Officers, CTO/CISO, Delivery Leads

19. MULTI-AGENT DELEGATION CHAINS — THE HARDEST PROBLEM

Single-agent 3LO is a solved problem. The harder frontier — and the one that will define the GENAI Agent Foundry's architecture as agents become orchestrators — is **multi-hop delegation**: when an orchestrator agent spawns sub-agents, each of which may call tools or other agents. At each hop, three questions must be answered: (1) whose authority is this acting under? (2) how has scope been constrained at each hop? (3) is there an auditable chain?

19.1 The Delegation Chain Problem

OAuth's RFC 8693 token exchange was designed for pairwise exchange, not multi-hop agent chains. Three structural limitations emerge in production:

Limitation	Description	Risk in GENAI context
No cross-domain trust	Each trust domain needs its own auth server. No mechanism for cross-domain token verification without pre-established federation.	Agents calling Atlassian + Graph + GHE in sequence each need separate token exchange — no shared trust fabric.
Opaque delegation history	Token exchange produces a new token with no cryptographic record of the original delegation chain.	Audit log cannot prove 'Sub-Agent B acted because Orchestrator A was delegated by User X'. Chain is asserted, not proven.

Limitation	Description	Risk in GENAI context
No holder-side attenuation	Only the auth server can narrow scopes. An intermediary agent cannot further constrain what it delegates.	If Orchestrator receives write:jira-work, it can delegate the full scope to Sub-Agent — even if Sub-Agent only needs read.

19.2 The act Claim — What RFC 8693 Gives You Today

RFC 8693 token exchange does support the **act claim** in the resulting JWT, which carries actor identity. This is the minimum viable audit chain available today and should be used in all multi-agent flows.

```
# Token resulting from OBO exchange (decoded JWT payload) { "sub": "user@bank.com", # The user on
whose behalf we act "oid": "a3b4c5d6-...", # User object ID "act": { # RFC 8693 actor claim "sub":
"agent-identity-sp-id", # Which Agent Identity is acting "act": { # Nested: who delegated to this
agent "sub": "orchestrator-agent-id" } }, "scp": "read:jira-work", # Scope – MUST be intersection,
never union "aud": "api.atlassian.com", # RFC 8707: bound to specific resource "exp": 1750000000,
"iat": 1749996400 } # The act chain: token is for user, via orchestrator, via agent-identity # Each
hop MUST exchange for a narrower or equal scope – never broader # Log the full JWT payload (minus
sensitive fields) for audit
```

■ RFC 8693 delegation chain splicing: a compromised intermediary can present a valid `subject_token` and a valid `actor_token` from DIFFERENT delegation contexts. The auth server cannot detect this without cryptographic binding. Mitigation: short token TTL + audience binding (RFC 8707) + `correlation_id` logged at every hop.

19.3 Practical Multi-Agent Pattern for GENAI Foundry

Until the IETF OAuth WG formalises cryptographic chain binding (draft-mw-spice-actor-chain), the pragmatic production pattern is the **scope attenuation ladder**:

Hop	Actor	Token received	Exchange to	Scope rule
0 — User	Human user signs in	User token Tc (full delegated scope)	Passes Tc to Orchestrator	User's full consent scope
1 — Orchestrator	Orchestrator Agent Identity	Receives Tc; exchanges via OBO to T_orch	Passes T_orch to Sub-Agent or Tool	Request ONLY what current task needs — not full Tc scope
2 — Sub-Agent	Sub-Agent Agent Identity	Receives T_orch; exchanges via OBO to T_sub	Passes T_sub to Tool/API	Further narrow: only scope for this specific tool call
3 — Tool/API	Resource server (Jira, Graph)	Receives T_sub; validates audience + scope	Executes API call	User permissions always constrain regardless of scope on token

✓ Scope attenuation is a MUST at each hop. Never pass an orchestrator's full scope to a sub-agent. Each exchange should request only what is needed for the immediate task. This is the primary defence against excessive agency in multi-agent pipelines.

19.4 Correlation & Audit Across Agent Hops

```
# Every agent call must carry and propagate correlation metadata # In HTTP headers (add to all
inter-agent calls): X-Correlation-ID: {uuid4} # Generated at user request entry; propagated
unchanged X-Agent-Chain: orchestrator-v2,sub-agent-jira-v1 # Append each agent name
X-Delegation-Depth: 2 # Hop count (enforce max depth = 3 in gateway policy) X-User-OID: a3b4c5d6-...
# Original user OID – never allow agent to override # Audit log entry at each hop (structured JSON):
{ "correlation_id": "cf3a...", "agent_id": "sub-agent-jira-v1", "user_oid": "a3b4c5d6-...",
"delegated_by": "orchestrator-v2", "action": "PATCH", "resource": "jira/DEMO-123/status",
"scope_used": "write:jira-work", "hop_depth": 2, "token_exp": 174999600, "timestamp":
```

"2026-06-28T10:15:00Z", "result": 200 } # This enables the CISO query: 'Show everything agent-chain X did on behalf of user Y' # Also required for DORA ICT incident reporting (see Section 21)

19.5 Maximum Delegation Depth Policy

Policy	Recommended value	Rationale
Max delegation depth	3 hops (user → orchestrator → sub-agent → tool)	Beyond 3, audit chain is practically unverifiable; attack surface grows exponentially
Min scope at each hop	Only the scope required for the immediate tool call	Principle of least privilege; prevents sub-agents inheriting orchestrator's full authority
Token TTL reduction	Each hop halves the remaining TTL	Limits blast radius if a mid-chain token is compromised; ensures chain expires
Max concurrent chains	Policy-defined per agent blueprint	Prevent agent spawning unbounded sub-agent trees; enforce in AC Gateway
Correlation ID required	Mandatory — reject calls without it	Without it, audit reconstruction across hops is impossible

20. THE 2026 AGENT PROTOCOL STACK: MCP + A2A + STREAMABLE HTTP

The ecosystem has converged on a **three-layer protocol stack** for production agent systems. Understanding where each protocol sits determines how authentication is layered and what the AC Gateway must handle for GENAI Agent Foundry agents calling external services.

Layer	Protocol	Governs	Auth mechanism	Status (June 2026)
Tool access	MCP (Model Context Protocol) — Anthropic, Linux Foundation	How agent calls tools, reads data, invokes prompts	OAuth 2.1 + PKCE mandatory for remote HTTP servers; Dynamic Client Registration	Production; 2025-11-05 spec; mandated by ChatGPT (Sept 2025), Claude, Copilot
Agent coordination	A2A (Agent-to-Agent) — Google, Linux Foundation	How agents delegate tasks to other agents; capability discovery via Agent Cards	RFC 8693 token exchange; OAuth 2.0 M2M per agent identity	v1.0 released April 2026; 150+ orgs including AWS, Microsoft, Salesforce, SAP
Transport	Streamable HTTP (MCP 2025-03-26 spec)	Bidirectional streaming between agent and tool server	Bearer token in Authorization header; token bound to session via RFC 8707	Replaced SSE as primary MCP transport; production in all major frameworks
Identity layer	IETF drafts: AIMS, WIMSE, Agentic JWT, SCIM for agents	Cryptographic agent identity, cross-domain trust, agent lifecycle	Emerging: AIP (Agent Identity Protocol) proposes Invocation-Bound Capability Tokens	Draft stage; no single standard adopted yet; watch IETF OAuth WG

20.1 How MCP Auth Works (2025-11-05 Spec)

The MCP specification now mandates OAuth 2.1 for all remote (HTTP) MCP servers. The flow is initiated when an unauthenticated MCP client contacts a protected server:

Step	Actor	Action
1	MCP Client (Agent)	Contacts MCP server without auth
2	MCP Server	Returns 401 + Protected Resource Metadata (RFC 9728) pointing to authorization server
3	MCP Client	Fetches auth server metadata; performs Dynamic Client Registration if needed
4	MCP Client	Runs OAuth 2.1 Authorization Code + PKCE flow (for user-delegated) or Client Credentials (for M2M)
5	Auth Server (Entra ID)	Issues access token bound to MCP server audience (RFC 8707 resource indicator)
6	MCP Client	Includes Bearer token in all subsequent calls to MCP server
7	MCP Server	Validates token: signature, expiry, audience == this server's URI

✓ November 2025 MCP spec adds: mandatory PKCE for all clients, Client ID Metadata Documents (CIMD) as preferred registration method, step-up authorization for incremental scope consent. These are all compatible with the 3LO pattern in this document.

20.2 How A2A Auth Works (v1.0)

A2A uses Agent Cards (JSON-LD documents) for capability discovery and OAuth M2M tokens for per-agent authentication. When Orchestrator delegates to Sub-Agent:

```
# Agent Card (published by Sub-Agent at /.well-known/agent.json) { "name": "JiraSubAgent",
"version": "1.2", "url": "https://jira-agent.genai.bank.internal/a2a", "capabilities": ["jira:read",
"jira:write"], "authentication": { "type": "oauth2", "tokenEndpoint":
"https://login.microsoftonline.com/{tid}/oauth2/v2.0/token", "scopes":
["api://jira-sub-agent/.default"] }, "identity": { "entraAgentIdentityId": "sub-agent-sp-object-id"
} } # Orchestrator calls Sub-Agent via A2A: POST https://jira-agent.genai.bank.internal/a2a/tasks
Authorization: Bearer {T_sub_from_RFC8693_exchange} X-Correlation-ID: {parent_correlation_id}
X-Delegation-Depth: 2 { "taskId": "task-uuid", "input": {"action": "update_status", "issue":
"DEMO-123", "status": "Done"}, "context": {"user_oid": "a3b4c5d6", "delegated_by":
"orchestrator-v2"} }
```

20.3 Protocol Choice Matrix for GENAI Agent Foundry

Scenario	Protocol	Auth pattern	AC Gateway role
Agent calls Jira/Confluence REST API	Direct HTTPS (no MCP/A2A)	3LO: per-user refresh_token in vault → access_token injected at gateway	Credential vault lookup + injection + audit log
Agent calls internal MCP tool server (e.g., Jira MCP)	MCP (Streamable HTTP)	OAuth 2.1 Bearer token; gateway proxies and re-signs with agent identity	Token validation inbound + outbound MCP auth header injection
Orchestrator delegates to Jira sub-agent	A2A v1.0	RFC 8693 OBO exchange; scope attenuated at each hop; act chain in JWT	Enforce max delegation depth; validate act chain; propagate correlation_id
Agent acts autonomously (no user context, org-level task)	Direct HTTPS or MCP	2LO: Client Credentials via Blueprint → Agent Identity fmi_path chain	App credential vault; no per-user token needed; audit with agent_id only
Agent triggers high-risk action across any protocol	CIBA (overlaid on any transport)	Suspend action; send backchannel approval request to user; resume on approve	CIBA decision endpoint; approval state machine; timeout/rejection handling

21. REGULATORY COMPLIANCE: DORA, NIS2 & EU AI ACT

As a EU financial institution (Bank is subject to DORA as of 17 January 2025), AI agents that access ICT systems are within scope of DORA and NIS2. The 3LO + AC Gateway architecture directly satisfies several mandatory obligations. This section maps each regulatory requirement to the technical controls in this design.

21.1 DORA — Digital Operational Resilience Act (Reg. EU 2022/2554)

DORA became fully applicable 17 January 2025. In 2026, regulators have moved from reviewing paperwork to demanding real-time proof of control. The five DORA pillars and their mapping:

DORA Pillar	Specific requirement	How this architecture addresses it
1. ICT Risk Management	Article 6-10: Identify, protect, detect, respond, recover. Log all ICT operations.	Every agent API call logged with agent_id, user_oid, scope, resource, result, timestamp. Audit trail queryable for incident reconstruction. Entra Identity Protection detects anomalous token usage.
2. ICT Incident Reporting	Article 17-19: Classify, report to NCA within 24h (early warning), 72h (full report).	P0 incident playbook (Volume 2 §15) maps to DORA classification. Structured logs enable automated incident reporting. Correlation IDs allow reconstructing full impact scope for regulators.
3. Digital Operational Resilience Testing	Article 24-27: Annual TLPT (Threat-Led Penetration Testing) for significant institutions.	Token vault, AC Gateway, and Entra Agent ID are in-scope ICT systems for TLPT. Include 3LO token theft scenarios, delegation chain splicing, and prompt injection in test plans.
4. ICT Third-Party Risk	Article 28-44: Register all ICT third-party providers. Assess concentration risk.	Entra ID (Microsoft), GitHub Enterprise, Atlassian, AWS are all ICT third parties. Must be in the Register of Information. Microsoft is a designated CTPP (Critical Third-Party Provider) under DORA — EU oversight applies directly. Assess concentration risk if all agents depend on Entra.
5. Information Sharing	Article 45: Voluntary sharing of cyber threat intelligence.	Agent token abuse patterns (unusual scope requests, unexpected countries, after-hours activity) are shareable threat indicators. Consider ISAC membership for financial sector AI threat intel.

21.2 NIS2 — Network and Information Security Directive

Banks are 'essential entities' under NIS2 Annex I Sector 4. DORA is lex specialis (takes precedence) for ICT risk management, but NIS2 still applies for CSIRT reporting and supply chain security.

NIS2 Article	Requirement	Architectural control
Art. 21 — Security measures	Access control, least privilege, MFA, encryption, audit logging	3LO per-user scoped tokens (not shared accounts). FIC+MSI (no passwords). AES-256-GCM vault encryption. Full audit log. Conditional Access enforced at blueprint level.
Art. 21 — Supply chain security	Assess security of ICT suppliers and their practices	Atlassian, GitHub, Microsoft are ICT suppliers for agent-accessed data. Their 3LO implementations must be assessed: PKCE enforced? Refresh token rotation? Scope granularity?
Art. 22 — Incident reporting	Early warning within 24h of significant incident to national CSIRT	P0 playbook (§15.2) includes CSIRT notification step. Significant incident = agent accessing data it was not authorised to access, or credential vault breach.

NIS2 Article	Requirement	Architectural control
Art. 21 — Continuity	Business continuity plans covering ICT systems	Token vault fallback: if vault unavailable, agents must gracefully degrade (not silently fail open). Circuit breaker: if Entra unavailable, agent queue tasks rather than proceeding without auth.

21.3 EU AI Act — High-Risk System Considerations

The EU AI Act (applicable August 2026 for high-risk systems) intersects with DORA via Article 9(10), which explicitly permits integrating AI risk management into DORA ICT risk procedures. Agents that access user data and make decisions affecting customers may be classified as high-risk.

EU AI Act obligation	Applicability	Control mapping
Human oversight (Art. 14)	High-risk: agent makes decisions affecting users (credit, fraud, customer service actions)	CIBA gate for irreversible actions. Access Reviews for agent permissions. Human escalation path in agent workflow design.
Technical documentation (Art. 11)	High-risk: full lifecycle documentation required	This Volume 1-3 document series. Confluence spec template (§17). Architecture Decision Records.
Logging & audit (Art. 12)	High-risk: logs must enable post-hoc reconstruction of AI decisions	Full delegation chain log (§19.4). User OID + agent_id + scope + resource + timestamp on every call. Retained per DORA retention schedule.
Data governance (Art. 10)	Training data and input data quality	Scoped tokens limit what data agent can read. read:jira-work scope prevents agent from accessing financial core systems via the same identity.
Conformity assessment (Art. 43)	Third-party assessment for high-risk systems	Entra Agent ID, AC Gateway, and credential vault are in-scope for conformity assessment if agent system is classified high-risk.

★ Practical advice: If agents are used for customer-facing decisions (fraud flagging, service actions), classify as high-risk early and design to EU AI Act Art. 14 (human oversight) from the start. Retrofitting human oversight into a production agent is significantly harder than designing it in.

22. AGENT IDENTITY GOVERNANCE MODEL — THREE LINES OF DEFENCE

DORA explicitly requires three independent lines of defence for ICT risk. Adapted for AI agent identity and access management:

Line	Role	Responsibilities for agent identity	Tools
Line 1 — Agent Owner / Builder	Business unit / team that builds and operates the agent	Define minimal scope set. Register OAuth apps with least-privilege scopes. Implement sidecar pattern. Configure CIBA gates for high-risk tools. Ensure offline_access only requested when background operation is needed.	Entra Agent ID portal, AC Gateway config, Atlassian/GHE dev console
Line 2 — Security / Identity Team	Independent risk function	Review all new agent identity registrations (FT/Entra self-service process). Define consent flow standards. Set Conditional Access policies on blueprints. Monitor Entra Identity Protection alerts for agent identities. Perform quarterly access reviews on all agent identities.	Entra admin centre, Identity Protection, Access Reviews, Security SIEM
Line 3 — Internal Audit	Independent assurance	Annual audit: verify Line 1 controls work (scope minimality, token isolation, sidecar pattern enforced). Verify Line 2 independence (Security not bypassed). Sample audit log entries: confirm agent_id + user_oid + scope present on all entries. DORA TLPT coordination: confirm agents are in-scope for penetration testing.	Audit sampling tools, log analytics, TLPT coordination

22.1 Agent Registry — Mandatory for Governance at Scale

At GENAI Agent Foundry scale, an **Agent Registry** is not optional — it is the foundation for compliance, security reviews, and operational management. Every deployed agent identity must be registered with the following mandatory fields:

Field	Type	Purpose
agent_id	UUID (Entra Agent Identity SP object ID)	Primary key; used in all audit logs
blueprint_id	UUID (Entra Blueprint app registration ID)	Links instance to its policy template
agent_name	String	Human-readable; appears in consent screens and audit UIs
owning_team	Team/org identifier	Line 1 accountability; notified on Access Review
security_sponsor	Entra user UPN	Line 2 accountability; approves scope changes; DORA: designated responsible person
provider_connections	Enum[]	Which providers this agent can access: atlassian, graph, ghe, ...
scopes_granted	String[]	Explicit list of all delegated scopes; reviewed quarterly
consent_model	Enum	admin_pre_consent user_3lo ciba_required
risk_tier	Enum	read_only standard high_risk critical (triggers CIBA requirement)
registered_at	Timestamp	Creation date; dormant agents flagged after 90 days without use
last_active	Timestamp	Updated by vault on every credential access; drives dormancy detection
dora_in_scope	Boolean	Whether this agent is in scope for DORA incident reporting and TLPT

22.2 Access Review Schedule

Review type	Frequency	Who performs	Trigger	Output
Quarterly scope review	Every 90 days	Security sponsor + owning team	Entra Access Review scheduled job	Confirm each scope still needed; remove unused scopes; escalate if dormant
Annual full review	Yearly	Security team + Internal Audit	Annual governance calendar	Full agent identity inventory; decommission unused; DORA evidence
Event-triggered review	On incident / personnel change	Security team	Entra Identity Protection alert OR agent owner leaves org	Immediate review of all agent identities owned by departing person; transfer or revoke
Pre-deployment review	Before every new agent goes live	Security team (Line 2 sign-off)	New agent registered in Agent Registry	Scope approval; consent model approval; risk tier assignment; DORA scoping decision

23. FORWARD-LOOKING: THE 2027 PROTOCOL HORIZON

The identity and authorisation landscape for AI agents is moving faster than any preceding generation of identity standards. The following emerging standards are at draft stage as of June 2026 and are likely to reach production relevance within 12–18 months. The GENAI Agent Foundry architecture should be designed to adopt these without a full rewrite.

23.1 Emerging IETF Standards (2026 Drafts)

Draft	What it defines	Relevance	Likely timeline
draft-oauth-ai-agents-on-behalf-of-user (-02, Aug 2025)	Extends Auth Code flow: requested_actor param names the agent on consent screen; actor_token authenticates agent at token endpoint	Directly relevant: users will see agent name on Atlassian/Graph consent screens. Design consent flow UI to accommodate this now — add agent name display even before draft is ratified.	Expected OAuth WG adoption 2026-2027
draft-mw-spice-actor-chain	Cryptographically verifiable actor chains for OAuth 2.0 Token Exchange — binds each hop cryptographically	Solves delegation chain splicing (§19.2). When ratified, replace correlation_id approach with cryptographic binding.	Draft stage; experimental implementations 2026
draft-ietf-oauth-identity-chaining	OAuth identity and authorisation chaining across trust domains	Solves cross-domain agent calls (Entra agent calling Google Workspace, for example). Relevant if GENAI agents need to federate across partner organisations.	Active WG discussion; 2027 target
WIMSE (Workload Identity in Multi-Service Environments)	Cross-service workload identity standard; agent as a workload identity type	Complementary to FIC/MSI. Standardises how agent identity is asserted across cloud boundaries without cloud-provider-specific FIC mechanisms.	Draft 2026; production 2027
SCIM for AI Agents (IETF 2026)	Agent lifecycle management: provisioning, deprovisioning, attribute management via SCIM	Will standardise the Agent Registry (§22.1) schema and automate agent deprovisioning via standard SCIM DELETE calls to Entra.	Early draft; watch for adoption
AIP: Agent Identity Protocol (arxiv 2603.24775)	Invocation-Bound Capability Tokens (IBCTs) — offline attenuable delegation with cryptographic provenance	Academic proposal addressing all 7 agent identity requirements that OAuth alone cannot satisfy. Not yet an IETF draft — monitor for commercialisation.	Research 2026; potential standardisation 2027+

23.2 Platform Roadmap Watch

Platform	Expected development	Impact on this architecture
Microsoft Entra Agent ID	Agent 365 admin centre (M365 admin view for all agents). GA of beta Graph APIs (agentIdentities). SCIM provisioning for agent identities. Expanded CA policy types for agents.	Simplifies agent registry — Agent 365 may replace bespoke registry. GA APIs remove beta risk.
Atlassian	Admin-level revocation for 3LO grants (currently only per-user or app uninstall). Richer MCP server for Jira/Confluence.	Solves OQ-3 (admin cannot revoke per-user grant). MCP server removes need for direct REST token management.

Platform	Expected development	Impact on this architecture
GitHub Enterprise	Fine-grained PATs reaching enterprise admin controls. GitHub App improvements for org-level agent access.	Reduces reliance on OAuth App long-lived tokens. Fine-grained PATs solve the GHE refresh token gap.
MCP + A2A joint spec (Q3 2026 target)	AAIF-governed joint specification bridging MCP tool calls and A2A agent coordination at auth layer	Will likely define a unified token format for tool-call + agent-delegation. Reduces dual-implementation burden (one MCP server + one A2A endpoint per service today).
Google Gemini Enterprise Agent Platform	Agent Gateway announced April 2026: enforces policy on A2A + agent-to-tool connections	Competitive reference architecture for AC Gateway. Study design for policy enforcement patterns.

24. AGENT AUTH MATURITY MODEL — WHERE ARE YOU NOW?

Use this model to assess current state and plan the maturity journey. Each level builds on the previous. The Minimal Delivery (GENAIAF-562 MD-1 to MD-3) targets Level 3.

Level	Name	Characteristics	Key missing from below	Target for GENAI Foundry
0 — Unsafe	Credential in agent	Static API keys or service account tokens embedded in agent code or env vars. No per-user isolation. No audit trail. Global blast radius.	Everything	NOT acceptable. Zero tolerance policy.
1 — Authenticated	Agent has identity	Agent has its own Entra service principal. Uses client credentials (2LO). Tokens not in code — in Key Vault or env. Centralised logging.	User delegation. Per-user scope isolation. Audit chain.	Minimum for autonomous (non-user-data) agents
2 — Delegated	User-delegated access (3LO)	3LO consent flow implemented. Per-user refresh_tokens in encrypted vault. Proactive refresh. Rotating tokens. User can revoke. Scope minimised.	FIC/MSI (no client secrets). CIBA. Multi-agent chain controls.	Target for MD-1, MD-2, MD-3 (Minimal Delivery)
3 — Governed	Auditable + policy-enforced	FIC+MSI credential (no secrets). AC Gateway as PEP. OPA policy on every tool call. CIBA for high-risk actions. Full act chain in audit log. Access Reviews quarterly. Agent Registry. Three lines of defence operating.	Cross-domain federation. Cryptographic chain binding. SCIM provisioning.	Target for Phase 2-3 production readiness
4 — Resilient	DORA/NIS2 compliant + tested	All Level 3 controls + DORA TLPT in scope for agents. CTPP concentration risk assessed. Automated incident reporting pipeline. EU AI Act conformity assessed. Chaos engineering: token vault outage → graceful degradation, not fail-open.	Emerging standards (AIP, WIMSE, SCIM-agents). Cross-org A2A federation.	Target for Phase 3 + regulatory audit readiness
5 — Adaptive	Cryptographically provable + federated	Invocation-Bound Capability Tokens (or equivalent). Cryptographic act chain. Cross-domain trust without pre-established federation. Automated SCIM lifecycle. Real-time risk-adaptive token issuance.	N/A — frontier state	2027+ horizon; watch IETF drafts

24.1 Current State Assessment for GENAIAF-562

Domain	Current level	Gap to Level 3	Priority
Agent identity (Entra Agent ID)	Level 0-1 (not yet deployed)	Full Level 2-3 implementation per this spec	High — blocked on infra
Credential management	Level 0 (not implemented)	Encrypted vault + FIC/MSI + proactive refresh	High — design now
User consent (3LO)	Level 0 (not implemented)	Consent flow + per-user token isolation	High — MD-2 blocker
Audit logging	Level 1 (basic app logs)	Full delegation chain log per §19.4	Medium — implement with gateway

Domain	Current level	Gap to Level 3	Priority
Security governance	Level 1 (informal)	Agent Registry + quarterly Access Reviews + three LoD	Medium — MD-2 target
DORA compliance	Level 1 (partially assessed)	Agents in Register of Information + TLPT scope	High — regulatory obligation
Multi-agent chains	Level 0 (not designed)	Scope attenuation ladder + max depth policy	Low — design now, implement Phase 2
Protocol stack (MCP/A2A)	Level 0 (not deployed)	MCP OAuth 2.1 for tool connections; A2A for orchestration	Low — Phase 2-3

25. MASTER DELIVERY ROADMAP — ALL VOLUMES SYNTHESISED

Phase	Timeline	Maturity target	Key deliverables	Blockers / Dependencies
Phase 0 Unblocked now	Q3 2026	Level 1 → 2 design	1. This research (Volumes 1-3) published in Confluence 2. Security/Identity alignment session (MD-2) 3. Atlassian + GHE OAuth app registrations (dev tenant) 4. Entra Agent Identity Blueprint registered (dev tenant) 5. Agent Registry schema designed and approved 6. Credential vault schema + encryption design approved 7. Scope minimisation guide per provider published	None — all can proceed immediately
Phase 1 After GENAI TB-201	Q3-Q4 2026	Level 2 — Delegated	1. AC Gateway live with 3-plane architecture 2. Credential vault deployed (encrypted, KMS-backed) 3. 3LO consent flow live (Atlassian + GHE) 4. OBO flow live (Graph API via sidecar) 5. Proactive refresh with distributed locking 6. Full audit log: agent_id + user_oid + scope + resource + ts 7. Reference implementation merged (MD-3)	AC Gateway whitelist (GENAITB-201) AC Identity whitelist (GENAITB-201) FT/Entra self-service Security approval
Phase 2 Production hardening	Q4 2026 – Q1 2027	Level 3 — Governed	1. FIC+MSI credential on all blueprints (no client secrets) 2. OPA policy engine on AC Gateway (RBAC + ABAC) 3. CIBA gate live for high-risk tool actions 4. Agent Registry live + integrated with Entra lifecycle 5. Quarterly Access Reviews scheduled and running 6. Multi-agent scope attenuation ladder implemented 7. Correlation_id propagated across all agent hops 8. OWASP Agentic Top 10 review completed	Phase 1 complete OPA/policy engine decision CIBA provider selection
Phase 3 DORA readiness	Q1-Q2 2027	Level 4 — Resilient	1. Agents added to DORA Register of Information 2. CTPP concentration risk documented (Microsoft, Atlassian, GitHub) 3. TLPT scope includes agent identity + AC Gateway + token vault 4. EU AI Act conformity assessment completed (if high-risk agents) 5. Automated incident reporting pipeline (P0/P1 → DORA notification) 6. Chaos tests: vault outage → graceful degradation (not fail-open) 7. MCP OAuth 2.1 adopted for all tool server connections 8. A2A v1.0 adopted for orchestrator → sub-agent delegation	Phase 2 complete Regulatory engagement timeline MCP/A2A joint spec maturity
Phase 4 2027 horizon	Q3 2027+	Level 5 — Adaptive	1. IETF draft-oauth-ai-agents-on-behalf-of-user adopted → agent named on consent screen 2. Cryptographic act chain (draft-mw-spice-actor-chain) deployed 3. SCIM for agents → automated lifecycle provisioning 4. Cross-domain A2A federation with external partners 5. Risk-adaptive token issuance (shorter TTL on elevated risk score)	IETF drafts reaching RFC status Platform support (Entra, Atlassian, GHE) MCP+A2A joint spec release

SERIES EXECUTIVE SUMMARY — VOLUMES 1, 2 & 3

The problem is real and urgent. AI agents acting on behalf of users across M365, Atlassian, and GHE need user-delegated auth that is auditable, least-privilege, and compliant with DORA. 93% of production agent projects use unscoped API keys. 79% of organisations have deployed agents; only 14% have full security

approval. The gap is the opportunity this spec addresses.

The solution is standardised and production-proven. The EntraID 3LO pattern — Blueprint → FIC/MSI → Agent Identity → OBO token exchange → per-user scoped access — is in production at Microsoft, AWS, Auth0, TrueFoundry, and Atlassian. No new primitives are needed. What is needed is disciplined implementation.

The three non-negotiables remain: (1) no client secrets — FIC+MSI; (2) per-user token isolation with encrypted vault and proactive refresh; (3) full audit trail: agent_id + user_oid + scope + resource + timestamp on every call. Everything else — CIBA, multi-agent chains, MCP/A2A, DORA compliance — builds on these three.

The blockers are infrastructure, not design. GENAITB-201 (AC Gateway + AC Identity whitelisting) is the critical path item. Phase 0 work — design, alignment, app registrations, schema — can proceed immediately while GENAITB-201 is resolved. Target: Level 2 (Delegated) by end of Q4 2026; Level 3 (Governed) by Q1 2027; Level 4 (DORA-resilient) by Q2 2027.